

CHALLENGE #1: Forbidden Paths Write-up

Forbidden Paths

Medium

Web Exploitation

picoCTF 2022

AUTHOR: LT 'SYREAL' JONES

Description

Can you get the flag?
We know that the website files live in `/usr/share/nginx/html/` and the flag is at `/flag.txt` but the website is filtering absolute file paths. Can you get past the filter to read the flag?
Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.
Its current status is:
NOT_RUNNING

Launch Instance

Hints

(None)

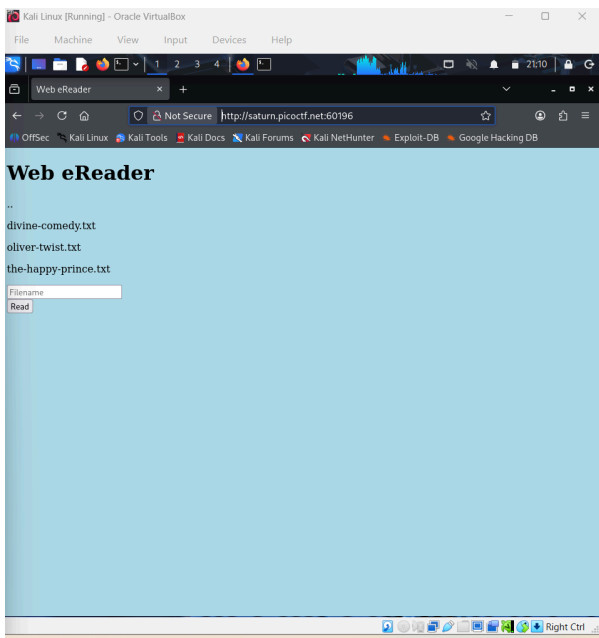
32,478 users solved

88% Liked

picoCTF{FLAG}

Submit Flag

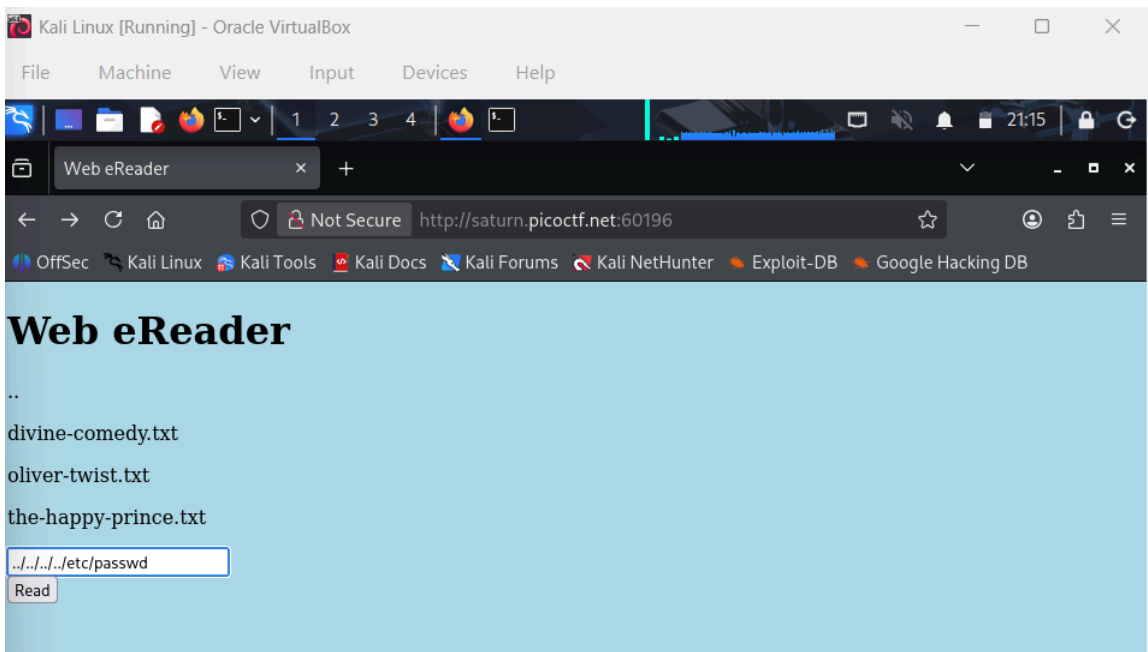
Solving Process:



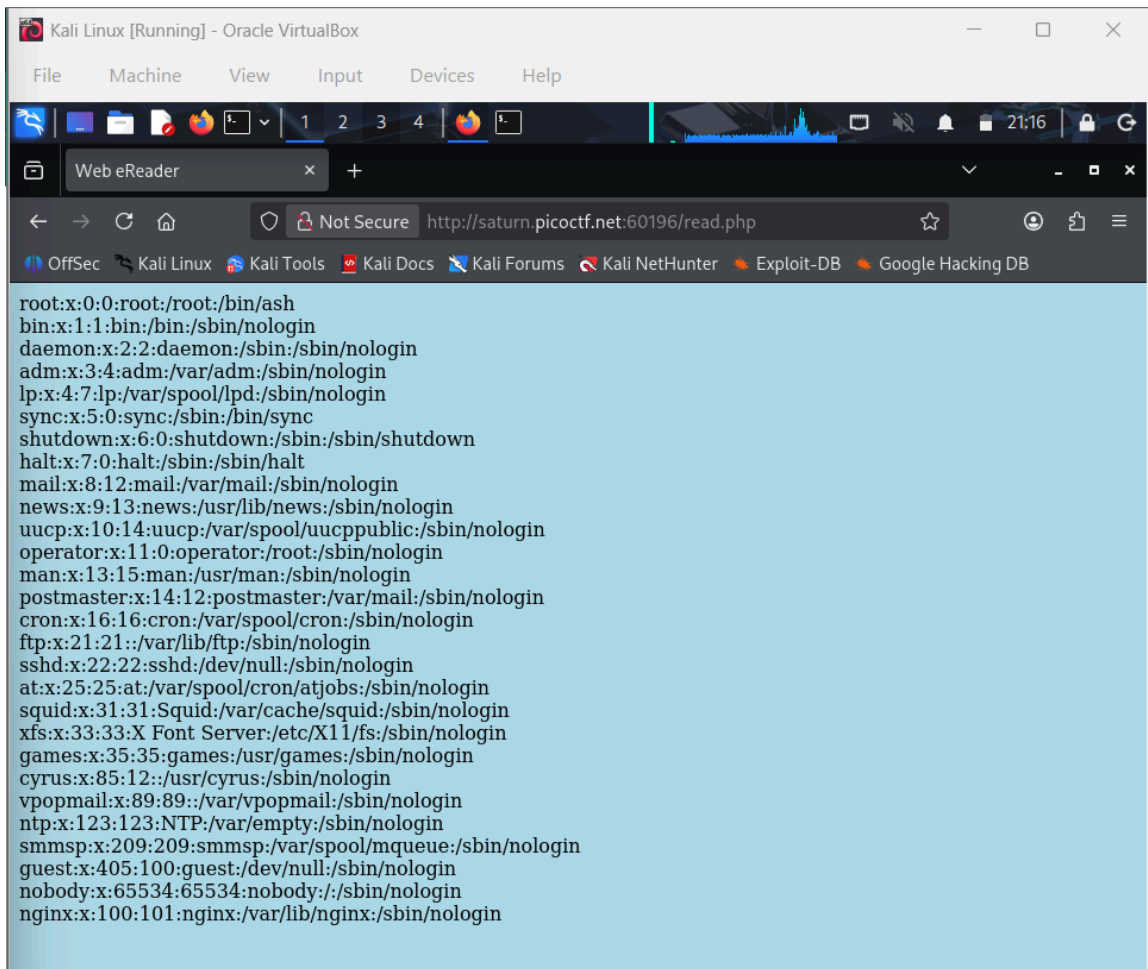
Upon opening the website, it was observed that the application functions as a web reader that allows users to read files from the server. The interface listed three files and allowed a user to input a file name in order to read its contents. For example, entering a file name such as `oliver_twist.txt` successfully displayed the content of that file from the system.

Next, the application was tested for a **Local File Inclusion (LFI)** vulnerability. Local File Inclusion occurs when a web application allows users to access files on the server by manipulating file paths. This vulnerability often allows attackers to read sensitive system files if they know or can guess their locations.

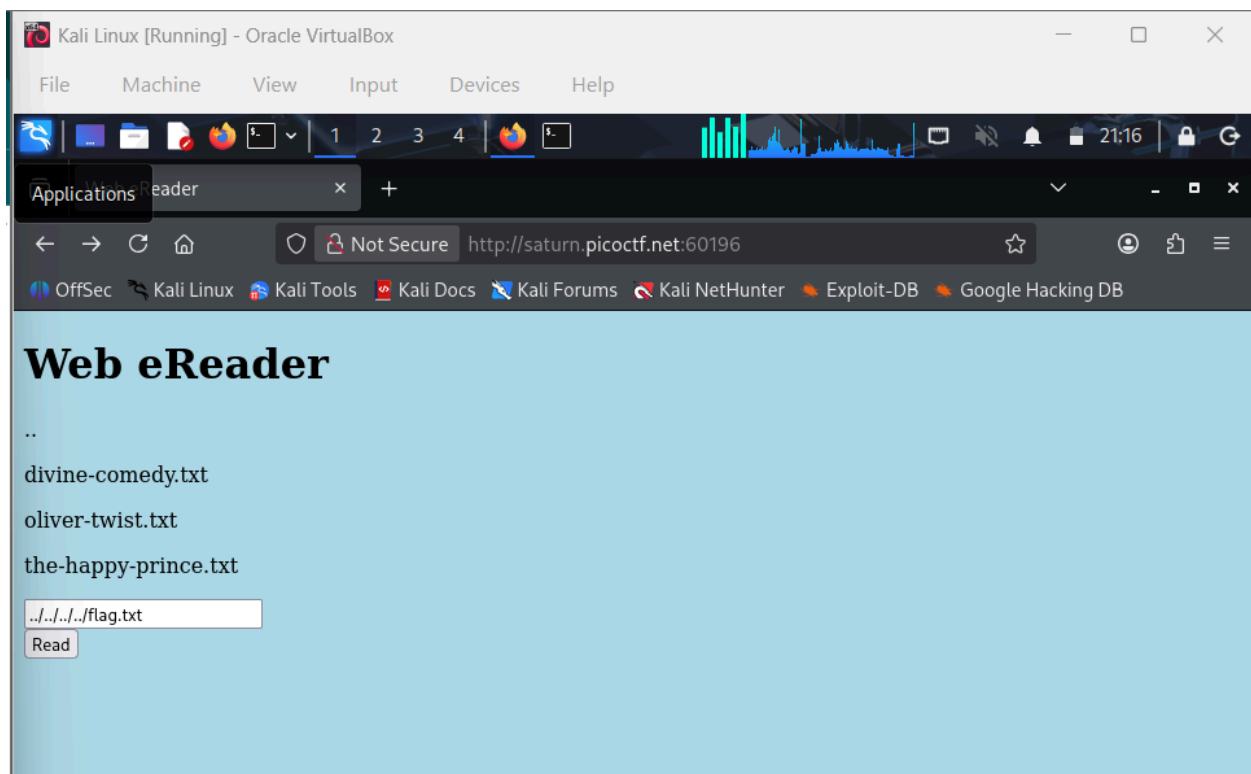
To exploit LFI, directory traversal techniques are commonly used. This involves using `../` (dot-dot slash) sequences to move up directories in the file system. Based on the challenge description, the application was located four directories deep within the server's file structure. Therefore, four `../` sequences were needed to navigate back to the root directory. The payload constructed for testing was: `../../../../etc/passwd`



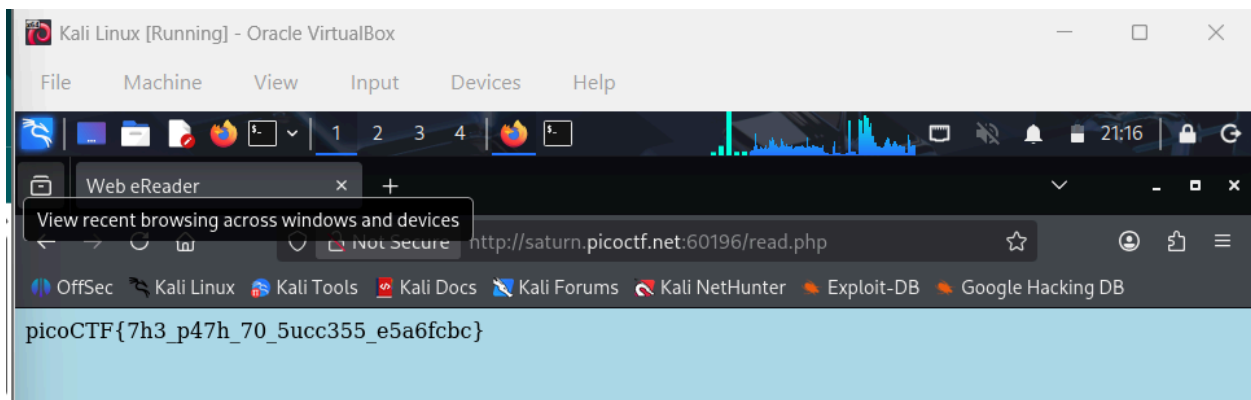
This payload attempts to access the `/etc/passwd` file, which is commonly used in Linux and Unix systems to store information about user accounts. After entering the payload and clicking Read, the system returned the contents of the `/etc/passwd` file. This confirmed that the application was vulnerable to Local File Inclusion, since it allowed access to sensitive files outside the intended directory.



After confirming the vulnerability, the next step was to retrieve the challenge flag. The challenge description specified that the flag was located at `/flag.txt`. To access this file using the same directory traversal technique, the following payload was used: `../../../../../../flag.txt`



After entering this path and clicking Read, the application displayed the contents of `flag.txt`, successfully revealing the flag.



Forbidden Paths

Medium

Web Exploitation

picoCTF 2022

AUTHOR: LT 'SYREAL' JONES

Description

Can you get the flag?

We know that the website files live in `/usr/share/nginx/html/` and the flag is at `/flag.txt` but the website is filtering absolute file paths. Can you get past the filter to read the flag?

Here's the [website](#).

This challenge launches an instance on demand.

Its current status is: RUNNING

Instance Time Remaining: 14:52

Restart Instance

Hints

(None)

32,478 users solved

88%

Liked

picoCTF{7h3_p47h_70_5ucc355_e5a6fcbc}

Submit Flag

Hurray! You solved this challenge.

Reflection:

This activity helped me understand how Local File Inclusion (LFI) vulnerabilities occur when web applications fail to properly validate user input for file paths. By experimenting with directory traversal (../), I learned how attackers can move through the server's file system to access sensitive files such as /etc/passwd and retrieve restricted data like the flag. Overall, the challenge showed the importance of secure input validation and proper file access controls to prevent unauthorized access to system files.